

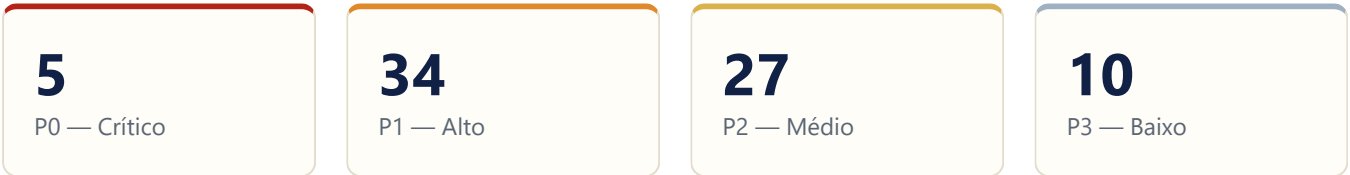
Auditoria geral de qualidade

Diagnóstico completo de UI, UX, responsividade, acessibilidade, segurança, código e fluxos de compra e venda, com plano de implementação por etapas.

Projeto	CloudMind — marketplace de produtos digitais
Data	25/09/2026
Documento	Versão 2 — diagnóstico e relatório final da implementação
Itens avaliados	76 itens classificados (5 críticos)

Sumário executivo

A auditoria encontrou **76 itens classificados**. Os **5 itens críticos** envolvem segurança (XSS no painel administrativo, fechamento de tickets de outros usuários), perda de dados de compradores e erros exibidos ao usuário. A base do sistema é sólida nos fluxos refeitos recentemente (produto, carrinho, pedidos e downloads), e a maior parte do trabalho restante é de consistência: levar para o site inteiro as soluções que a página de produto já tem.



Tipo	Quantidade
● Problema	30
● Melhoria importante	18
● Polimento	28

Corrigir antes de qualquer outra coisa

- C1 — XSS armazenado no painel admin
- C2 — Exclusão sem confirmação no painel do vendedor
- C3 — IDOR nos tickets de suporte
- C4 — Compradores perdem as compras
- C5 — Erro 500 ao enviar ticket inválido estando logado

Índice

- | | |
|--|--|
| 1. Contexto e método | 10. Segurança: complementos |
| 2. Arquitetura atual | 11. SEO e metadados |
| 3. Problemas críticos (P0) | 12. Sugestões futuras |
| 4. Problemas de prioridade alta (P1) | 13. Componentes a padronizar |
| 5. Melhorias de UX | 14. Decisões tomadas |
| 6. Consistência visual | 15. Plano de implementação |
| 7. Melhorias técnicas e de performance | Anexo A — Itens ainda fictícios |
| 8. Responsividade | Anexo B — Relatório final da implementação |
| 9. Acessibilidade | |

1. Contexto e método

Objetivo. Revisão completa do CloudMind antes da colocação em produção. A revisão procura problemas funcionais, de segurança, de responsividade, de acessibilidade, de consistência visual e de acabamento. O resultado desejado é "o mesmo CloudMind, porém mais profissional, consistente, intuitivo, responsivo, robusto e bem acabado", preservando rotas, dados, regras de negócio e identidade visual.

Escopo lido. Todo o código da aplicação:

- `app.js` e `config/db.js`, incluindo as migrações automáticas.
- Os dois routers (`router.js` e `routerAdm.js`), os 11 models, os helpers e o validator.
- As 23 views de página, os partials estruturais (`menu`, `sidebar`, `footer`, `btnV`) e os 12 partials da página de produto.
- Os 36 arquivos CSS e os 16 arquivos JavaScript do front.
- O schema em `config/SCRIPT.sql`.

Limites. A auditoria foi feita por leitura de código. O aplicativo não foi executado nesta etapa, porque o `.env` aponta para um MySQL compartilhado no Clever Cloud, com limite de 5 conexões, onde a equipe também testa. Itens que dependem de renderização real estão marcados como **(confirmar no navegador)** e são verificados na fase de implementação.

Legenda.

Marcador	Significado
 Problema	Algo errado ou que pode quebrar
 Melhoria importante	Funciona, mas pode melhorar de forma significativa
 Polimento	Melhoria visual, de UX ou de consistência
 Sugestão	Funcionalidade ou melhoria adicional, não necessária agora

Prioridade	Critério
P0 — Crítico	Pode quebrar funcionalidade, causar perda de dados ou falha de segurança grave
P1 — Alto	Impacta significativamente a experiência ou o funcionamento
P2 — Médio	Melhoria relevante, mas não crítica
P3 — Baixo	Polimento ou melhoria menor

2. Arquitetura atual

- **Stack.** Express 5 com EJS renderizado no servidor, sessão com `express-session` e MySQL via `mysql2` com pool de 4 conexões. Uploads usam `multer`, senhas usam `bcryptjs`, validações usam `express-validator` e e-mails usam `nodemailer`.
- **Páginas.** Cada página é um `.ejs` completo, com o próprio `<head>` e o próprio arquivo CSS. As partes compartilhadas são os parciais `menu`, `sidebar`, `footer` e `btnV`.
- **Rotas.** `routerAdm.js` atende `/paineladm` e `/adm/*`. `router.js` atende o restante: páginas públicas, catálogo, produto, carrinho, pedidos, downloads, conta, painel do vendedor e suporte. Um middleware impede o administrador de sair do painel administrativo.
- **Dados.** Usuário, com perfis de cliente, criador e administrador; produto, com galeria em `produto_imagem`; carrinho; pedido; avaliação; pergunta; favorito; suporte; denúncia.
- **Arquivos.** Os arquivos entregues ao comprador ficam fora de `app/public`, em `storage/produtos`, e só saem pela rota autorizada `/downloads/:id`. As imagens de apresentação são públicas.
- **Pagamento.** Simulado. Todo pedido nasce como `pago`, e o ponto de troca para um gateway real é `helpers/pagamento.js`.
- **Referência de qualidade.** A página de produto (`paginnerprod.ejs`, `produto.css`, `produto.js` e `partials/produto/`) é a parte mais madura do sistema. Ela tem tokens próprios, gradiente estável, footer no fluxo, foco visível, estados de erro e vazio, toast e live regions. **A estratégia central de melhoria é promover essas soluções a uma base compartilhada**, em vez de criar um design novo.

3. Problemas críticos (P0)

- **C1 P0** ● **XSS armazenado no painel admin.** Em `paineladm.ejs`, o nome do usuário entra num `onsubmit="return confirm('... <%= u.nome %> ...')"`. O EJS converte `'` em `'`, mas o navegador desfaz essa conversão no atributo antes de executar o JavaScript. Um usuário cadastrado com o nome `');alert(1);(`, que tem 15 caracteres e passa no validador, executa código no navegador do administrador quando ele clica em Excluir. Com isso, o atacante consegue disparar ações administrativas. **Correção:** passar o texto em `data-confirmar` e usar um único handler delegado (`js/confirmar.js`) que lê o `dataset`.
- **C2 P0** ● **Exclusão sem confirmação no painel do vendedor.** A causa é a mesma do C1, em `admvend.ejs`. Um título com apóstrofo, como "Guia do Pai d'Água", quebra o JavaScript inline. O `onsubmit` falha e o formulário exclui o produto sem perguntar. **Correção:** a mesma do C1.
- **C3 P0** ● **IDOR nos tickets de suporte.** `POST /suporte/cancelar` e `/suportelogado/cancelar` chamam `Suporte.fechar(id)` sem verificar o dono do ticket. Qualquer usuário logado consegue fechar o ticket de outro. **Correção:** `Suporte.fecharDoUsuario(id_chamada, id_usuario)`, com `WHERE id_usuario = ?`.

- **C4 P0** ● **Compradores perdem as compras.** `Produto.excluir` apaga o `item_pedido` e as avaliações dos compradores. `Usuario.excluir`, chamado pelo administrador, faz o mesmo com todos os produtos de um vendedor. Nenhum dos dois usa transação, então uma falha no meio deixa o banco inconsistente. **Correção aprovada: exclusão lógica.**
 - O ENUM `produto.status_produto` ganha o valor `'excluido'`, por migração idempotente em `config/db.js` e registro em `SCRIPT.sql`.
 - Produto com venda: o status vira `'excluido'`. O produto sai do catálogo, da busca, dos relacionados, dos favoritos e do painel, mas o comprador mantém o download, o pedido e a avaliação.
 - Produto sem venda: exclusão física, agora numa transação e removendo também as imagens do disco.
 - Conta de vendedor com vendas: os produtos viram `'excluido'` e a conta é suspensa, sem apagar registros de compra.
- **C5 P0** ● **Erro 500 ao enviar ticket inválido estando logado.** O `verificarErros` renderiza a página de suporte sem a variável `tickets`. O EJS, que usa `with(locals)`, lança `ReferenceError`. Como não existe tratador de erros, o Express mostra o stack trace ao usuário. **Correção:** tratamento próprio no `validarSuporte` e um tratador global de erros.

4. Problemas de prioridade alta (P1)

4.1 Funcionais

- **F1 P1** ● **"Excluir conta" falha para vendedor.** `denuncia.id_cliente` tem chave estrangeira para `cliente`. Um vendedor que nunca usou o carrinho não tem linha em `cliente`, então o INSERT falha e ele volta para `/config` sem aviso. **Correção:** garantir a linha com `Cliente.buscarOuCriar` e mostrar uma mensagem de erro.
- **F2 P1** ● **"Ver detalhes" nos Favoritos leva a /pprodutos1.** É a página legada, com catálogo fictício e HTML quebrado. **Correção:** apontar para `/paginnerprod?id=` e redirecionar `/pprodutos1?id=X` com 301.
- **F3 P1** ● **Busca, filtros e paginação do catálogo não funcionam.** O input não tem `name`, os botões de filtro não têm ação, as sugestões são uma lista fixa com produtos inexistentes e a paginação usa `href="#"`. **Correção:** `GET /PProdutos?q=&tipo=&pagina=` com filtro no servidor, paginação real e sugestões com títulos reais, sem mudar o schema.
- **F4 P1** ● **Não há página 404 nem tratamento global de erro.** Aparecem "Cannot GET /x" ou o stack trace. **Correção:** `pages/erro.ejs`, no padrão dos estados da página de produto, com tratadores de 404 e 500.
- **F5 P1** ● **GET /adm renderiza pages/adm, que não existe.** **Correção:** redirecionar para `/paineladm`.
- **F6 P1** ● **Mensagens de retorno se perdem.** O servidor redireciona com `?msg=conta_inativada`, mas o login só trata `solicitacao_enviada`. A Home ignora `?msg=conta_reativada`. **Correção:** lista fixa de mensagens conhecidas.

- **F7** **P1** ● **A sidebar sempre marca "Minhas compras" como ativo. Correção:** marcar o item da página atual, com `aria-current="page"`.
- **F8** **P1** ● **Depois do login, a pessoa sempre cai na Home.** Isso acontece mesmo quando ela tentou comprar, favoritar ou perguntar num produto. **Correção:** guardar o destino em `session.voltarPara`, aceitando só caminhos relativos para evitar open redirect.
- **F9** **P1** ● **Publicar um produto termina no catálogo sem retorno. Correção:** voltar ao painel do vendedor com o aviso "Produto publicado" e um link para a página do produto.
- **F10** **P1** ● **E-mail duplicado ao editar dados gera "Erro ao atualizar dados". Correção:** tratar `ER_DUP_ENTRY` com uma mensagem específica.
- **F11** **P1** ● **Front e servidor validam diferente.** O front do cadastro aceita qualquer nome e o servidor exige de 10 a 50 caracteres. A dica de senha omite maiúscula e minúscula. O login exige 8 ou mais caracteres no front. **Correção aprovada:** nome de 3 a 50 caracteres, com nome e sobrenome. Resumo do produto de 10 a 150 caracteres. Mesmas regras no front e no servidor, mostradas antes do envio.
- **F12** **P1** ● **Vendedor consegue comprar o próprio produto. Correção:** recusar no servidor e esconder o botão para o dono.
- **F13** **P1** ● **Envio de ticket e cadastro sem POST/redirect/GET.** Atualizar a página depois de enviar duplica o ticket. **Correção:** redirect com aviso guardado na sessão.
- **F14** **P1** ● **Upload de avatar falha em silêncio.** Não há aviso de erro, de tamanho ou de formato. Só a extensão é validada. O avatar do header fica em cache e não se atualiza. **Correção:** validar a assinatura da imagem, mostrar retorno ao usuário e usar cache-busting.
- **F15** **P1** ● **O campo "Quantidade em estoque" do Wizard é ignorado.** Produto digital não tem estoque, por decisão já tomada. **Correção:** remover o campo.
- **F16** **P1** ● **A reputação do vendedor nunca aparece.** `criador.media_avaliacoes` nunca é atualizado. **Correção:** calcular a partir de `avaliacao_produto`.

4.2 Conteúdo fictício

- **D1** **P1** ● **Home.** Estatísticas inventadas ("+1.200 produtos", "+4.500 vendedores", "4.7★"), depoimentos inventados e promessas não implementadas: comissão de 10%, entrega por e-mail, gamificação e selos, categoria Flashcards.
- **D2** **P1** ● **Catálogo.** Nota ★★☆☆☆ fixa em todos os cards. Slider com "até 70% de desconto" e botões sem ação. FAQ que promete produtos gratuitos, embora o validador exija no mínimo R\$ 0,01, e "recebimento direto na conta", embora o pagamento seja simulado.
- **D3** **P1** ● **Painel do vendedor.** Gráfico de vendas e avaliações recentes fixos. "Solicitar saque" sem função. "Pedidos recentes" com o texto "Em breve", e um "Ver todos" que leva às compras do próprio usuário.
- **D4** **P1** ● **Painel admin.** Os três gráficos usam números fixos.
- **D5** **P1** ● `/perfilvend`. Página inteiramente inventada.
- **D6** **P1** ● **Configurações.** Tema, idioma, notificações, sessões ativas, privacidade e 2FA exibido como ativo não têm função.

- **D7 P1** ● **Botões sem função.** Login social, "Esqueceu a senha?", cupom do carrinho e busca do suporte. O FAQ do suporte cita cartão de crédito, que não existe, e indica o caminho errado para editar o nome.
- **D8 P1** ● **Sobre Nós.** O título diz "DigitalHub", a marca aparece como "CloudMind" e os textos alternativos das fotos citam outras pessoas.
- **Tratamento aprovado.** Nada é escondido. Nesta rodada, o que as tabelas atuais permitem vira dado real, sem mudar o schema:
 - notas no catálogo;
 - vendas, pedidos e avaliações no painel do vendedor;
 - números e gráficos do admin;
 - estatísticas da Home;
 - sugestões de busca.
- O restante continua visível e está listado no **Anexo A**, com o que falta para virar funcionalidade real numa próxima rodada.

4.3 Segurança

- **S1 P1** ● **Sessão.** O `secret` está fixo no código. O cookie não define `sameSite` nem `secure` de forma explícita. As sessões ficam em memória. **Correção:** `SESSION_SECRET` no `.env`, cookie com `httpOnly`, `sameSite: 'lax'` e `secure` sob HTTPS.
- **S2 P1** ● **Login.** O login não regenera a sessão, o que permite fixação de sessão, e não limita tentativas. **Correção:** `session.regenerate` e um limitador em memória por IP e e-mail.
- **S3 P1** ● **Suspensão e exclusão não derrubam a sessão ativa**, que dura até 8 horas. **Correção:** revalidar o status a cada 5 minutos no middleware de autenticação.
- **S4 P1** ● **O administrador pode suspender ou excluir a si mesmo e a outros administradores.** **Correção:** bloquear no servidor e esconder os botões.
- **S5 P1** ● **E-mails HTML interpolam o nome do usuário sem escapar.** **Correção:** escapar o nome.
- **S6 P1** ● **/adm/testar-email** **expõe parte da senha SMTP, e o mailer desliga a verificação TLS.** **Correção:** remover a rota e verificar TLS em produção.
- **S7 P2** ● **Faltam cabeçalhos de segurança.** São eles `X-Frame-Options`, `nosniff` e `Referrer-Policy`. **Correção:** um middleware simples, sem dependência nova.

5. Melhorias de UX

- **U1 P2** ● **HTML estrutural quebrado nos partials.** `menu.ejs` fecha um `</header>` aberto pela página e injeta um `<main>` vazio. Os footers ficam aninhados, com padding triplicado. `btnV.ejs` abre uma `<section>` que nunca fecha. **Correção:** partials autocontidos.
- **U2 P2** ● **Header.** Não há "Entrar/Criar conta" para visitantes nem estado ativo. "Inicio" está sem acento. O carrinho tem `alt="Market"`. O hamburger não tem `aria-label`. O menu mobile não tem links de conta. O administrador vê links que só redirecionam.

- **U3 P2** ● **Cards e botões usados como links via `onclick` e `data-link`**. Não abrem em nova aba e não funcionam pelo teclado. **Correção:** usar `<a>` reais.
- **U4 P2** ● **Estados vazios inconsistentes**. Carrinho e favoritos mostram só um texto cinza, sem CTA.
- **U5 P2** ● **Carrinho**. Remover e limpar não dão retorno, a lixeira não tem nome acessível e o preço exibido pode divergir do preço cobrado.
- **U6 P2** ● **Cadastro concluído mantém o formulário na tela**. **Correção:** ir ao login com aviso e e-mail preenchido.
- **U7 P2** ● **Formulário de suporte**. O tipo do ticket aparece cru ("duvida"), os labels não têm `for` e o botão "Cancelar" limpa o formulário.
- **U8 P2** ● **"Voltar" usa `history.back()` e tira do site quem chegou por link direto**.
- **U9 P2** ● **Painel do vendedor**. A busca não funciona, o upload parte sem confirmação e as cores estão inline.
- **U10 P2** ● **Home**. A tecla "v" rola a página (WCAG 2.1.4). O conteúdo com animação de entrada fica invisível sem JavaScript. O carrossel ignora `prefers-reduced-motion`. Os cards de categoria parecem clicáveis e não são.
- **U11 P2** ● **Wizard**. O resumo só aceita 30 caracteres. Tipo e categoria são redundantes, e as categorias estão fixas no HTML.
- **U12 P3** ● **Títulos de página inconsistentes**. Exemplos: "Página de Login" e "Sessão de Produtos", onde o certo é "Seção".

6. Consistência visual

- **V1 P2** ● **O gradiente de fundo muda de tom conforme a altura da página, e o footer "flutua"**. Cerca de 20 arquivos CSS aplicam o gradiente no `<body>`, que estica pelo documento inteiro. A página de produto já resolveu isso com o body em coluna, `main { flex: 1 }` e duas faixas de gradiente de altura fixa. **Correção:** levar essa solução para uma base compartilhada.
- **V2 P2** ● **Tokens duplicados e divergentes**. O mesmo `:root` se repete em 20 arquivos. Há 4 dourados de ação, 3 azuis de link e raios de borda de 5, 6, 8 e 12px para botões equivalentes.
- **V3 P2** ● **Tipografia**. Poppins é declarada sem ser carregada, "Segoe UI" vem antes de Inter em alguns arquivos e `* { font-family: 'Inter' }` não tem fallback (**confirmar no navegador**).
- **V4 P2** ● **Reset CSS repetido**, com ordem de carregamento diferente por página.
- **V5 P2** ● **Font Awesome carregado duas vezes**, uma delas no footer, o que atrasa os ícones.
- **V6 P2** ● **Oito implementações diferentes de alerta**, além de três de badge de status e três de modal.
- **V7 P3** ● **Hover do menu quase invisível sobre o fundo escuro**.

7. Melhorias técnicas e de performance

- **T1** **P2** ● **Chart.js sem versão fixa.** Uma versão major nova pode quebrar os gráficos.
- **T2** **P2** ● **Imagens sem dimensões**, o que causa layout shift. A imagem principal da Home é externa.
- **T3** **P3** ● **Código morto.** `navbar.js`, `script1.js`, `Slider.js`, `validaF_cdstraprod.js`, `detail.css`, `ImgInicial.css`, `Bloco de Notas.css`, `app/data/produtos.js`, `teste-validacao.ejs`, `suporteloped.ejs`, `partials/erros.ejs` e a dependência `js`.
- **T4** **P3** ● **Middleware de autenticação duplicado nos dois routers.**
- **T5** **P3** ● `express.static` com caminho relativo ao diretório de execução.
- **T6** **P3** ● **Imagens órfãs em disco após excluir produto.**
- **T7** **P3** ● `package-lock.json` no `.gitignore`, o que torna as instalações não reproduzíveis.
- **T8** **P3** ● **Consulta duplicada em** `Usuario.buscarPorEmail`.
- **Mantido de propósito:** jQuery nas validações de formulário, porque trocá-lo agora seria refatoração sem ganho.

8. Responsividade

- **R1** **P1** ● **Offsets fixos para header e sidebar.** Cada página usa um `padding-top` diferente, de 280, 270, 150, 120 ou 100px. Uma regra `calc(70px+80px)` é inválida por falta de espaços e é ignorada. O menu mobile usa `top: 70px`, mas o header real mede cerca de 82px. **Correção:** altura do header medida em variável CSS e sidebar no fluxo no mobile.
- **R2** **P2** ● **A sidebar fixa fica acima do header** e pode cobrir o logo (**confirmar no navegador**). Com `height: 100vh` e sem rolagem, o "Sair" fica inacessível em telas baixas.
- **R3** **P2** ● **Tabelas com formulários por linha são difíceis de usar no celular.** **Correção:** layout em cards abaixo de 600px.
- **R4** **P3** ● **O modal de exclusão de conta não tem altura máxima nem rolagem interna.**

9. Acessibilidade

- **A1** **P1** ● **Não há foco visível em quase todo o site.**
- **A2** **P1** ● **Login e cadastro não têm** `<label>`, e os labels do suporte não têm `for`.
- **A3** **P1** ● **Controles sem nome acessível ou fora do alcance do teclado.** É o caso do "alterar foto", do "remover do carrinho", do hamburger e das redes sociais.
- **A4** **P2** ● **Modais sem gestão de foco**, e os do admin abrem por `<td onclick>`. **Correção:** `<dialog>` nativo.

- **A5** **P2** ● **Links das redes sociais sem nome acessível.** As URLs são mantidas por decisão do responsável pelo projeto.
- **A6** **P2** ● **Contraste de cerca de 2,5:1 em textos secundários sobre o bege.** O mínimo é 4,5:1.
- **A7** **P2** ● **Hierarquia de títulos incorreta** no catálogo, no perfil e no painel admin.
- **A8** **P2** ● **prefers-reduced-motion** é ignorado.

10. Segurança: complementos

- **Correto e mantido:**
 - arquivos privados fora da pasta pública;
 - proteção contra path traversal nos downloads;
 - preço lido do banco no checkout;
 - checagem de dono nas ações de produto;
 - validação da assinatura JPG/PNG;
 - transações no pedido e no cadastro de produto.
- **CSRF por token** ●: fica para o futuro. O `sameSite: 'lax'` explícito do S1 cobre o principal.

11. SEO e metadados

- **SEO** **P3** ● **Metadados incompletos.** Só a página de produto tem `description`, `canonical` e Open Graph. As páginas públicas passam a ter `description`, e as privadas `noindex`.
- `lang` aparece como "pt-br" e "pt-BR". O site não tem favicon, então cada página gera um 404 em `/favicon.ico`.

12. Sugestões futuras

- Edição de produto pelo vendedor.
- Recuperação de senha, que exige uma tabela de tokens.
- Página pública do vendedor.
- Login social.
- Gateway de pagamento real.
- Denúncia de produto pelo usuário. O model e o validator já existem.
- Barra de progresso real no upload.
- Prévia por tipo de produto: amostra de áudio, sumário, módulos.
- Store de sessão persistente.
- Tokens CSRF.

- Miniaturas otimizadas.
- Contador de itens no ícone do carrinho.
- `UNIQUE (id_cliente, id_produto)` em `avaliacao_produto`.

13. Componentes a padronizar

Componente	Situação atual	Padrão proposto
Head da página	Cada página carrega fontes, ícones e CSS de um jeito	<code>partials/head.ejs</code> com <code>base.css</code> , Inter e Font Awesome uma vez
Header, footer, sidebar, Voltar	Partials com HTML quebrado	Partials autocontidos
Botão	Quatro dourados e raios diferentes	Primário, secundário, ghost e perigo, em dois tamanhos
Alerta	Oito implementações	<code>.cm-alert</code> com sucesso, erro, aviso e informação
Estado vazio	Três formatos	<code>.cm-empty</code> com ícone, texto e CTA
Badge de status	Três versões	<code>.cm-badge</code> para pedido, ticket, produto e usuário
Modal	Três implementações com <code>div</code>	<code><dialog></code> nativo
Confirmação destrutiva	<code>confirm()</code> inline	<code>data-confirmar</code> com handler único
Campo de formulário	Placeholder como rótulo	Label, input, dica e erro
Tabela	Rolagem horizontal	Cards no mobile

14. Decisões tomadas

1. **Exclusão de produto vendido:** exclusão lógica, com o novo status `'excluido'`. É uma mudança de schema aprovada.
2. **Conteúdo fictício:** nada é escondido. O que as tabelas atuais permitem vira dado real, e o restante é documentado para a próxima rodada.
3. **Edição de produto:** fica para uma rodada futura.
4. **Validações:** nome de 3 a 50 caracteres, com nome e sobrenome. Resumo de 10 a 150 caracteres.
5. **Footer:** as URLs das redes sociais são mantidas.
6. **Documentação:** esta auditoria é salva em PDF. Uma segunda versão incluirá o relatório final da implementação.

7. Pendências conscientes:

- produtos de vendedor suspenso continuam à venda;
- a página pública do vendedor será definida junto com a equipe.

15. Plano de implementação

Etapa	Conteúdo
0	Este PDF e o checkpoint reversível em <code>_checkpoints/auditoria-2026-09-25/</code>
1 — Críticos	C1 a C5, página de erro e tratadores globais
2 — Funcionais e segurança	F1 a F16 e S1 a S7
3 — Base e responsividade	<code>base.css</code> , <code>partials/head.ejs</code> , partials corrigidos, header medido, sidebar no fluxo, tabelas e modais
4 — UX e dados reais	U2 a U12, D1 a D7 com dados reais, D8
5 — Consistência visual	V2 a V7
6 — Acessibilidade	A2 a A8 (A1 entra na etapa 3)
7 — Performance	T1, T2 e Font Awesome carregado uma vez
8 — Polimento	Títulos, SEO, favicon, textos e T3 a T8
9 — Relatório final	Anexo B deste documento

Verificação.

- Renderização de todas as views sem banco, em todos os estados e perfis.
- Checagem de status e redirecionamentos de todas as rotas.
- Testes de escrita com transação e ROLLBACK, sem gravar no banco compartilhado.
- Capturas em 360, 768, 1024 e 1440px.
- Percurso completo dos fluxos de compra, venda, conta, suporte e administração.
- Validação do checkpoint por hash.

Anexo A — Itens ainda fictícios

Situação ao final desta rodada (confirmada na implementação). A lista também está em [_checkpoints/auditoria-2026-09-25/README.md](#).

Item	Onde	Nesta rodada	O que falta para virar real
Estatísticas da Home	Main.ejs	Vira dado real	—
Depoimentos da Home	Main.ejs	Continua fictício	Coletar depoimentos reais, ou usar avaliações reais em destaque
Promessas da Home (comissão 10%, entrega por e-mail, gamificação, Flashcards)	Main.ejs	Continua fictício	Definir comissão, e-mail de entrega, selos e a categoria correspondente
Nota nos cards do catálogo	PProdutos.ejs	Vira dado real	—
Slider promocional ("70% de desconto")	PProdutos.ejs	Continua fictício	Campanhas e preços promocionais reais
Filtro OFERTAS	PProdutos.ejs	Continua fictício	Conceito de oferta, que exige schema
FAQ do catálogo	PProdutos.ejs	Continua fictício	Revisar textos quando existirem produto gratuito e repasse
Gráfico e avaliações do painel do vendedor	admvend.ejs	Vira dado real	—
Pedidos recentes do vendedor	admvend.ejs	Vira dado real	—
Saldo e "Solicitar saque"	admvend.ejs	Parcial: vendido real, saque sem função	Repasse ao vendedor, que exige gateway e schema
Gráficos do admin	paineladm.ejs	Vendas e tipos reais	"Usuários ativos" exige histórico de login
Perfil do vendedor	perfilvend.ejs , pgpublica.ejs	Continua fictício	Página pública do vendedor, a definir com a equipe
Configurações (tema, idioma, notificações, sessões, privacidade, 2FA)	config.ejs	Continua fictício	Preferências persistidas, 2FA e listagem de sessões

Item	Onde	Nesta rodada	O que falta para virar real
Login social e "Esqueceu a senha?"	login.ejs , cadastro.ejs	Continua fictício	OAuth e tabela de tokens de recuperação
Cupom do carrinho	carrinho.ejs	Continua fictício	Cupons, que exigem schema
Busca e FAQ do suporte	suporte.ejs	Continua fictício	Base de artigos de ajuda

Anexo B — Relatório final da implementação

Implementação concluída em 25/09/2026, na ordem aprovada: críticos, funcionais, responsividade, UX, consistência visual, acessibilidade, performance e polimento. Todas as rotas e URLs foram preservadas. A única mudança de schema foi a aprovada: o valor `'excluido'` em `produto.status_produto`. O checkpoint reversível está em `_checkpoints/auditoria-2026-09-25/`.

B.1 Corrigido

- **C1 e C2** — Confirmações passam por `data-confirmar` e pelo `confirmar.js`. Um nome com `');alert(1);(` aparece só como texto, e um título com apóstrofo não pula mais a confirmação.
- **C3** — `Suporte.fecharDoUsuario` checa o dono no próprio UPDATE. Outro usuário não fecha o ticket.
- **C4** — Exclusão lógica para produto vendido, física (em transação) para produto sem venda. Um vendedor com vendas excluído pelo admin é desativado, e nenhuma compra se perde.
- **C5 e F4** — O suporte usa POST/redirect/GET, o que acaba com o erro 500. Há páginas 404 e 500 amigáveis e tratador global de erros, sem stack trace para o usuário.
- **F1** — "Excluir conta" funciona para o vendedor que nunca comprou.
- **F2** — Favoritos levam à página real do produto. `/pprodutos1` redireciona com 301.
- **F3** — O catálogo tem busca, filtros por tipo, lista de categorias, paginação real e sugestões com títulos reais.
- **F5** — `/adm` redireciona para o painel.
- **F6** — Mensagens de retorno (conta inativada, reativada, sessão encerrada, saída) vêm de uma lista fixa.
- **F7** — A sidebar marca a página atual e ganhou o item "Meu perfil".
- **F8** — Depois do login, a pessoa volta à página ou ao produto de onde veio. Só caminhos internos são aceitos.
- **F9** — Publicar um produto leva ao painel com o aviso e o link da página.
- **F10** — E-mail já em uso tem mensagem própria.
- **F11** — Front e servidor usam as mesmas regras: nome e sobrenome de 3 a 50 caracteres, resumo de 10 a 150, título de 5 a 100 e senha com checklist visível.
- **F12** — O vendedor não compra o próprio produto, nem pelo servidor nem pela interface.
- **F13** — Ticket e cadastro seguem POST/redirect/GET, então atualizar a página não duplica nada.
- **F14** — O avatar tem validação de conteúdo, retorno visível, atualização no header e acesso pelo teclado.
- **F15** — Saiu o campo de estoque.
- **F16** — A reputação do vendedor é calculada das avaliações reais.
- **S1 e S2** — Sessão com `httpOnly`, `sameSite: 'lax'`, segredo pelo `.env`, regeneração no login e limite de 5 tentativas a cada 15 minutos.
- **S3** — Conta suspensa ou excluída perde a sessão em até 5 minutos.

- **S4** — O admin não suspende nem exclui administradores, nem a si mesmo.
- **S5** — Nomes escapados nos e-mails.
- **S6** — A rota de diagnóstico que expunha a senha SMTP foi removida, e o TLS é verificado em produção.
- **S7** — Cabeçalhos `X-Frame-Options`, `nosniff` e `Referrer-Policy`.
- **R1 e R2** — Não há mais offsets mágicos por página, e o header tem altura única. No celular, a sidebar entra no fluxo. No desktop, ela fica abaixo do header, sem cobrir o logo, e com rolagem própria.
- **V1** — O gradiente não muda mais de tom com a altura da página, e o footer sempre termina a página, com a mesma solução da página de produto.
- **U1** — Partials corrigidos: header e footer não ficam mais aninhados e não sobra `<section>` aberta.
- **D1 a D4 (trocados por dados reais)** — Notas nos cards do catálogo, estatísticas da Home, e no painel do vendedor gráfico, vendas recentes, avaliações recentes e total vendido. No admin, vendas mensais e distribuição de tipos.
- **D8** — Sobre Nós com a marca certa ("CloudMind"), título, `alt` s com os nomes reais e sem id duplicado.

B.2 Melhorado

- **Header.** Estado ativo, "Entrar/Criar conta" para visitantes, hamburger acessível, menu mobile com links da conta e navegação enxuta para o admin.
- **Formulários.** Labels visíveis, erros junto de cada campo, `aria-invalid`, mostrar/ocultar senha, prevenção de envio duplicado e foco no primeiro erro.
- **Estados.** Vazio com CTA, erro e sucesso padronizados em carrinho, favoritos, compras, downloads, painel do vendedor, suporte e admin.
- **Carrinho.** Mostra o preço atual (o mesmo cobrado), avisa quando o preço mudou, confirma antes de limpar, dá retorno ao remover e deixa o resumo fixo no desktop.
- **Painel do vendedor.** Busca real na tabela, checagem de formato e tamanho com confirmação antes de trocar arquivo, e texto de exclusão que diz se ela será lógica ou física.
- **Admin.** Modais em `<dialog>` abertos por botão, badges padronizados, categoria do ticket legível e avisos para cada ação.
- **Home.** Categorias viram links para o catálogo filtrado, o atalho da tecla "v" saiu, o conteúdo aparece sem JavaScript e o carrossel respeita o "reduzir movimento".
- **Tabelas.** Viram cards no celular (vendedor, admin e suporte).
- **Acessibilidade.** Foco visível em todo o site, link "Pular para o conteúdo", nomes acessíveis em ícones, hierarquia de títulos corrigida, contraste do texto secundário ajustado e `prefers-reduced-motion` respeitado.
- **SEO.** Títulos no padrão "Página — CloudMind", `description` nas páginas públicas, `noindex` nas privadas, favicon e `lang="pt-BR"` em todas as páginas.
- **Performance.** Font Awesome carregado uma vez (antes vinha também pelo footer), Chart.js com versão fixa e só quando há gráfico, imagens com dimensões e `loading="lazy"`, e jQuery removido das páginas que não precisavam.

B.3 Refatorado

- `partials/head.ejs` com `base.css`, que concentra tokens, reset, layout e componentes `.cm-*`. O `:root` e o reset deixaram de se repetir em 20 arquivos.
- Layouts compartilhados: `conta.css` para a área logada e `auth.css` para login e cadastro.
- `middlewares/auth.js` passou a ser único para os dois routers.
- `validacao.js` concentra as regras de validação do front.
- `site.js` concentra os comportamentos comuns, e `confirmar.js` cuida das confirmações.
- Os estilos inline e os blocos `<style>` das páginas foram movidos para os CSS delas.
- 22 arquivos mortos removidos, além da dependência `js`. O `package-lock.json` voltou a ser versionado.

B.4 Mantido

- Rotas, URLs e regras de negócio.
- Pagamento simulado, isolado em `helpers/pagamento.js`.
- Arquivos privados em `storage` e download protegido.
- Checagem de dono em produto, pedido e pergunta.
- Galeria, lightbox, abas, perguntas e avaliações da página de produto.
- O Wizard de publicação, com rascunho automático e galeria ordenável.
- Identidade visual: bege, navy, dourado e cards escuros.
- Os itens fictícios continuam visíveis, conforme a decisão do responsável (Anexo A).

B.5 Pendente

- **Os itens do Anexo A** continuam fictícios de propósito. São o escopo da próxima rodada.
- **Página pública do vendedor.** `/pgpublica`, `/perfilvend` e "Visitar perfil" dependem de uma definição conjunta.
- **Edição de produto.** Não existe, e foi adiada por decisão do responsável.
- **Vendedor suspenso.** Os produtos dele continuam à venda.
- **Exclusão de comprador.** Excluir a conta de um comprador apaga os pedidos dele, que também somem do histórico de vendas do vendedor.
- **Admin sem teste real.** A tela do admin foi verificada por prévia, e as regras por teste com ROLLBACK. O login real como admin não foi testado porque a senha do admin não foi usada.
- **Barra de progresso real no upload.** Hoje o envio usa o formulário nativo, com estado "Publicando...".
- **jQuery.** Continua no Wizard e na página pública, onde a troca não trazia ganho.

B.6 Sugestões futuras

- Recuperação de senha, com tabela de tokens.
- Login social.

- Gateway de pagamento real.
- Denúncia de produto pelo usuário.
- Store de sessão persistente.
- Tokens CSRF.
- Miniaturas otimizadas.
- Contador de itens no ícone do carrinho.
- `UNIQUE (id_cliente, id_produto)` em `avaliacao_produto`.
- Prévia por tipo de produto: amostra de áudio, sumário, módulos.

B.7 Verificação executada

Verificação	Resultado
Renderização de todas as views com dados de exemplo (22 páginas, vários estados, 4 perfis)	220/220 sem erro de template
Overflow horizontal em 360, 390, 768, 1024 e 1366 px (todas as páginas)	Nenhum (1 caso no carrinho corrigido)
Rotas como visitante: status, redirects, 404, 301 e cabeçalhos	32/32
Fluxos de ponta a ponta no app real (cadastro, login, publicação, compra, download, pergunta, avaliação, suporte, IDOR, exclusões lógica e física, F1)	48/48
Regras dos models com ROLLBACK (admin, catálogo, painéis, suporte, status)	21/21, nada gravado
Migração do ENUM	Idempotente: o segundo boot não altera o schema
Restauração do checkpoint numa cópia	131 arquivos com hash idêntico e 11 novos removidos
Dados de teste	Contas <code>teste.auditoria.*</code> e arquivos apagados; contagens do banco iguais às de antes